

Abstract

AI agents now hold genuine system authority: they execute code, touch credentials, open network egress, parse hostile documents, and in many deployments initiate or approve changes to the very infrastructure they run on. This review, dated 2026-09-10, examines what that shift does to operating-system security. The primary scenario is a technically capable operator whose workstation faces both **exploitation** — an attacker compromising a browser, parser, dependency, or agent tool and then crossing a boundary — and **authorized misuse** — an attacker persuading an agent to use its existing, legitimate access to exfiltrate secrets or authorize consequential actions. The second path requires no kernel exploit at all, which reframes the evaluation: the axis of analysis is the authority a component already holds, not merely the difficulty of exploiting it.

Abstract I

This revision (0.7.0) refreshes the evidence base through September 11, 2026. The offensive baseline expands from four primary sources to the incident record now available: the NCSC assessments of January 2024 and May 2025, the Anthropic campaign investigation of November 2025 — whose tradecraft MITRE has canonized as campaign C0062 — the August 2025 “vibe hacking” report and the September 2026 threat-intelligence report on credential theft, OpenAI’s disruption reporting and its October 2025 counterpoint, Google GTIG’s analysis of an autonomous credential-harvesting campaign, the OpenAI–Hugging Face evaluation incident of July 2026, the UK AI Security Institute’s unsanctioned-behavior incident (nineteen out-of-scope actions across seven models), and DARPA’s AIxCC finals, where AI systems identified and patched vulnerabilities, including real, non-synthetic ones, at measured rates. The platform reviews absorb the 2026 record: Qubes 4.3.0 (Xen 4.19, the sys-gui split, the Devices API, the salt management model, and

the QSB-118 dom0 injection, CVE-2026-82636) and Nix 2.34/2.35 with its advisory chain, the removal of the hardened profiles, and 95.18 percent measured ISO reproducibility. The analysis is situated against the standards landscape — the OWASP Agentic AI Threats and Mitigations guide and the December 2025 Top 10 for Agentic Applications, CSA's MAESTRO framework, the NIST AI Agent Standards Initiative, and the CISA-led Five-Eyes adoption guidance — and against the convergent sandboxing practice of the major coding agents, which together motivate the OS-level lens this review applies. A defensive-stack matrix (24 candidates against eight mitigation classes) joins the candidate–property matrix as a second deterministic artifact.

The review extends the underlying architectural assessment into three domains the source treatment only touches implicitly: **cognitive security** (the authorized-misuse surface, where persuasion substitutes for exploitation), **operator OpSec** (the practices that keep compartmentalization real under workload pressure), and **agent-orchestration security** (the boundary design of multi-agent systems themselves). Deep reviews of Qubes OS and NixOS anchor the analysis.

Abstract I

The review ships its concepts in two forms: the prose analysis, and a harness-neutral skill library (a `skills/` registry with conformance tests, following (Friedman 2026)) that lets an agent harness apply the evaluation vocabulary, the authority ladder, and the other review concepts directly. The evaluation artifacts — the candidate–property matrix and the defensive-stack matrix — regenerate deterministically from pinned data modules. The work is citable via its Zenodo DOI (printed on the cover).

Keywords: agentic security, operating systems, compartmentalization, capability mediation, Qubes OS, NixOS, threat modeling, cognitive security, operational security, agent orchestration, offensive AI, reproducible builds.